

Segurança da Informação

Atividade Prática

Leis, Normas e Padrões · Privacidade · Confiabilidade

Portal Interno de Automação Vivo

Análise de Conformidade Regulatória e Controles de Segurança

Guilherme Reis

Nicolas Lobo

Vinicius Trevisan

Professor: Luis Gonzaga de Paulo

Curitiba, Paraná — Maio de 2025

Sumário

1. Introdução.	3
2. Descrição do Projeto — Caso Real (Vivo / Telefônica Brasil)	3
3. Problemas e Riscos de Privacidade.	4
4. Problemas e Riscos de Confiabilidade.....	5
5. Regulamentações Aplicáveis.	6
5.1 LGPD — Lei Geral de Proteção de Dados (Lei 13.709/2018)	6
5.2 Marco Civil da Internet (Lei 12.965/2014).	7
5.3 ISO/IEC 27001 e 27002.	7
5.4 Resolução ANATEL 740/2020 — SGSI para Telecomunicações	8
5.5 PCI DSS (referência indireta).....	8
6. Controles e Mecanismos Propostos.	9
7. Benefícios da Conformidade.	10
8. Conclusão.	11
9. Referências Bibliográficas.	12

1. Introdução

Esta atividade prática tem como objetivo analisar a aplicabilidade de instrumentos regulatórios de segurança da informação em um projeto de software real. Para isso, o grupo optou por utilizar um caso concreto do ambiente de estágio: o **Portal Interno de Automação da Vivo (Telefônica Brasil)**, desenvolvido e mantido por um dos integrantes do grupo como único desenvolvedor responsável.

O documento está estruturado de forma a apresentar o projeto, identificar seus riscos de privacidade e confiabilidade, mapear as regulamentações aplicáveis e, por fim, propor controles e mecanismos que viabilizem a conformidade — argumentando sua importância para os responsáveis pelo investimento e decisão na organização.

2. Descrição do Projeto — Caso Real (Vivo / Telefônica Brasil)

A **Vivo**, maior operadora de telecomunicações do Brasil e subsidiária da Telefônica S.A., possui extensas operações internas que envolvem processos operacionais complexos. No contexto do estágio de desenvolvimento de software, foi criado um **ecossistema de automação e portais web internos** para otimizar fluxos que anteriormente demandavam intervenção manual intensiva.

2.1 Componentes do Sistema

O sistema é composto por três camadas principais:

Componente	Tecnologia	Função
Portal Web Interno	Next.js / React	Interface para operadores: consultas, relatórios, gestão de processos
Backend de Automação	Python (Flask / FastAPI)	APIs REST, regras de negócio, integração com sistemas legados
Robôs RPA	Python + Playwright	Automação de tarefas repetitivas em sistemas Vivo e parceiros
Banco de Dados	SQL Server / PostgreSQL	Armazenamento de dados operacionais, logs e relatórios

2.2 Dados Processados

O sistema processa dados altamente sensíveis, incluindo:

- **Dados pessoais de clientes:** CPF, nome, endereço, contatos, histórico de atendimento;
- **Dados funcionais internos:** credenciais, acessos, relatórios de desempenho;

- **Dados operacionais críticos:** configurações de rede, inventário de equipamentos, contratos com parceiros;
- **Logs de processos automatizados:** registros completos de execução dos robôs RPA.

2.3 Escopo e Sensibilidade

O portal é acessado por equipes internas distribuídas em diferentes unidades da Vivo, com autenticação via SSO corporativo. Os robôs de automação executam operações em sistemas que contêm dados de **dezenas de milhares de clientes**. A ausência de controles adequados representa risco regulatório, operacional e reputacional significativo para a empresa.

3. Problemas e Riscos de Privacidade

A análise de privacidade identificou os seguintes riscos principais:

3.1 Acesso Indevido a Dados de Clientes

Os robôs RPA acessam sistemas legados que contêm CPF, endereço e dados contratuais de clientes. Não há, atualmente, um mecanismo formal de *data minimization* — os scripts recuperam conjuntos completos de dados quando poderiam operar apenas com campos necessários para a tarefa específica. Isso amplia a superfície de exposição em caso de falha ou comprometimento.

3.2 Ausência de Log de Auditoria Detalhado sobre Acesso a Dados Pessoais

Embora existam logs de execução dos robôs, não há rastreabilidade granular de *quais dados pessoais foram acessados, por qual processo e em qual momento*. Isso dificulta a resposta a incidentes e a prestação de contas exigida pela LGPD (art. 37 e 48).

3.3 Retenção Indefinida de Dados em Cache e Logs

Dados de clientes são eventualmente armazenados em arquivos temporários e tabelas de staging sem política de expiração definida. A LGPD determina que dados pessoais devem ser eliminados após cumprir sua finalidade (art. 15), o que não é observado no fluxo atual.

3.4 Risco de Vazamento via Credenciais Hard-coded

Em algumas versões anteriores dos scripts de automação, credenciais de acesso a sistemas legados foram armazenadas em texto plano em arquivos de configuração. Embora parcialmente mitigado, o risco de reintrodução desse padrão existe na ausência de um processo formal de revisão de código com foco em segurança.

3.5 Transferência de Dados para Sistemas de Parceiros

Alguns fluxos de automação enviam dados de clientes para APIs de parceiros comerciais. Não há verificação sistemática de que esses parceiros possuem DPIA (Relatório de Impacto à Proteção de Dados) ou cláusulas contratuais adequadas, conforme exigido pela LGPD para operadores de dados.

4. Problemas e Riscos de Confiabilidade

4.1 Ponto Único de Falha — Ausência de Redundância

O sistema é desenvolvido e mantido por um único desenvolvedor. Não existe documentação técnica suficiente para que outro profissional assuma a operação em caso de ausência. Isso configura risco operacional crítico, especialmente considerando que os processos automatizados suportam operações de negócio contínuas.

4.2 Ausência de Ambiente de Homologação Formal

Atualizações nos robôs RPA são testadas em ambiente local antes de ir para produção, mas não existe um ambiente de homologação espelhando o ambiente produtivo com dados anonimizados. Isso aumenta o risco de falhas em produção com impacto direto em processos críticos.

4.3 Ausência de Monitoramento Proativo e Alertas

Falhas nos robôs de automação são detectadas majoritariamente de forma reativa — quando um usuário reporta um problema. Não há integração com ferramentas de monitoramento (ex.: alertas de falha por e-mail/Teams, dashboards de saúde dos processos), o que compromete o RTO (Recovery Time Objective).

4.4 Dependência de Sistemas Legados sem Contratos de SLA

Os robôs interagem com sistemas legados da Vivo que não possuem SLA formal para uso interno. Indisponibilidades nesses sistemas derrubam os processos automatizados sem mecanismo de retry ou circuit breaker, causando impacto em cascata.

4.5 Backup e Recuperação de Desastres

Não existe um plano formal de DR (Disaster Recovery) para o portal e seus dados associados. Backups do banco de dados são realizados por infraestrutura corporativa, mas o procedimento de restauração específico para a aplicação nunca foi testado.

5. Regulamentações Aplicáveis

5.1 LGPD — Lei Geral de Proteção de Dados (Lei 13.709/2018)

A LGPD é a principal norma aplicável ao projeto, dado o volume e a sensibilidade dos dados pessoais de clientes processados. Os artigos de maior relevância incluem:

Artigo	Requisito	Impacto no Projeto
Art. 6º	Finalidade, adequação e necessidade (data minimization)	Robots devem acessar apenas dados estritamente necessários
Art. 37	Manutenção de registros de operações de tratamento	Logs auditáveis de acesso a dados pessoais são obrigatórios
Art. 46	Adoção de medidas de segurança técnicas e administrativas	Criptografia, controle de acesso, testes de segurança
Art. 48	Notificação de incidentes à ANPD e titulares	Plano de resposta a incidentes e canal de comunicação
Art. 15	Término do tratamento e eliminação de dados	Política de retenção e descarte de dados em staging/cache

5.2 Marco Civil da Internet (Lei 12.965/2014)

O Marco Civil estabelece princípios para o uso da internet no Brasil, com implicações diretas para sistemas que processam dados de usuários. O **art. 13** determina a guarda de registros de conexão e acesso a aplicações por 6 meses a 1 ano, respectivamente. O portal deve manter logs de acesso dos operadores internos por período mínimo compatível com essa exigência, além de garantir sigilo no tratamento de informações de usuários finais (clientes).

5.3 ISO/IEC 27001 e ISO/IEC 27002

A **ISO/IEC 27001** define os requisitos para um Sistema de Gestão de Segurança da Informação (SGSI), enquanto a **ISO/IEC 27002** fornece as diretrizes de controles. Embora a certificação formal não seja obrigatória por lei, a Telefônica possui compromissos internacionais com essas normas, e o portal deve estar alinhado. Os controles mais relevantes são:

- **A.9 — Controle de Acesso:** autenticação forte, princípio do menor privilégio, revisão periódica de acessos;
- **A.10 — Criptografia:** proteção de dados em trânsito (TLS 1.2+) e em repouso;
- **A.12 — Segurança nas Operações:** gestão de vulnerabilidades, backups, monitoramento;
- **A.14 — Desenvolvimento Seguro:** SSDLC (Secure Software Development Lifecycle), revisão de código, testes de segurança;
- **A.16 — Gestão de Incidentes:** plano de resposta, registro e aprendizado com incidentes.

5.4 Resolução ANATEL 740/2020 — SGSI para Telecomunicações

A ANATEL, por meio da Resolução 740/2020, exige que prestadoras de serviços de telecomunicações (como a Vivo) implementem e mantenham um **Sistema de Gestão de Segurança da Informação** específico para o setor. Isso inclui proteção de infraestruturas críticas de telecomunicações, gestão de riscos cibernéticos e obrigação de notificar incidentes relevantes à ANATEL. O portal de automação, ao interagir com sistemas operacionais da Vivo, está no escopo desta regulação.

5.5 PCI DSS — Payment Card Industry Data Security Standard (referência indireta)

Embora o portal não processe diretamente dados de pagamento, fluxos que toquem dados de clientes com histórico de cobranças ou interajam com sistemas de billing da Vivo devem observar os controles PCI DSS para garantir segregação adequada de ambientes e não ampliar a superfície de ataque do escopo PCI da empresa.

6. Controles e Mecanismos Propostos

Com base na análise dos riscos e nas exigências regulatórias, o grupo propõe a implementação dos seguintes controles:

#	Controle	Risco Mitigado	Regulação
C1	Implementar data minimization nos scripts RPA: recuperar apenas campos necessários por tarefa	Privacidade — Exposição excessiva	LGPD Art. 6º
C2	Auditoria de acesso: log granular de quais dados pessoais foram acessados, por qual processo, quando	Privacidade — Rastreabilidade	LGPD Art. 37; MCI Art. 13
C3	Política de retenção: TTL definido para tabelas de staging e arquivos temporários (ex.: 7 dias)	Privacidade — Retenção indevida	LGPD Art. 15
C4	Gestão de segredos: migrar credenciais para cofre (ex.: HashiCorp Vault ou Azure Key Vault)	Privacidade — Credenciais expostas	ISO 27002 A.9
C5	Documentação técnica completa: runbooks, arquitetura e procedimentos de operação	Confiabilidade — Ponto único de falha	ISO 27001 A.7
C6	Ambiente de homologação com dados anonimizados espelhando produção	Confiabilidade — Falhas em produção	ISO 27002 A.12
C7	Monitoramento proativo: alertas de falha via Teams/e-mail, dashboard de saúde dos processos	Confiabilidade — Detecção reativa	ISO 27002 A.12; ANATEL 740

C8	Implementar retry com backoff exponencial e circuit breaker nas integrações com sistemas legados	Confiabilidade Dependência legados	—	ISO 27002 A.17
C9	Teste formal de DR: executar restauração completa do portal em ambiente isolado semestralmente	Confiabilidade Recuperação	—	ISO 27001 A.17
C10	Plano de resposta a incidentes de privacidade com prazo de notificação $\leq 72h$ à ANPD	Privacidade Confiabilidade	+	LGPD Art. 48; ANATEL 740

7. Benefícios da Conformidade

A adoção dos controles propostos gera benefícios tangíveis e intangíveis que justificam o investimento para os tomadores de decisão:

Dimensão	Benefício
Jurídico-Regulatório	Evitar multas da ANPD de até 2% do faturamento, limitadas a R\$ 50 milhões por infração (LGPD, art. 52). Evitar sanções da ANATEL por descumprimento da Resolução 740/2020.
Reputacional	Incidentes de vazamento de dados em empresas de telecomunicações têm ampla repercussão. A conformidade reduz risco reputacional e mantém a confiança dos clientes.
Operacional	Monitoramento proativo e documentação reduzem tempo de resposta a incidentes (MTTR), aumentam disponibilidade dos processos e eliminam o risco de parada total por indisponibilidade do desenvolvedor.
Competitivo	Conformidade com ISO 27001 e LGPD é requisito crescente em contratos B2B e licitações públicas, ampliando o mercado endereçável da Vivo.
Financeiro	Custo de conformidade preventiva é significativamente menor que o custo de remediação pós-incidente, que inclui investigação forense, notificações, compensações e honorários jurídicos.

8. Conclusão

A análise do Portal Interno de Automação da Vivo demonstrou que, mesmo sistemas desenvolvidos em contexto corporativo estabelecido, podem apresentar lacunas significativas de conformidade regulatória quando não há um processo formal de gestão de segurança da informação orientando o desenvolvimento.

O caso evidencia uma realidade comum em projetos de automação interna: a velocidade de entrega e a escassez de recursos (neste caso, um único desenvolvedor responsável) frequentemente relegam a segurança para segundo plano. No entanto, o arcabouço regulatório brasileiro — especialmente a LGPD e as regulações da ANATEL — não faz distinção entre sistemas voltados ao público externo e sistemas internos que processem dados pessoais de clientes.

A atividade reforçou que a conformidade regulatória não deve ser tratada como um custo, mas como um **investimento em sustentabilidade operacional e reputacional**. Os controles propostos — data minimization, auditoria granular, gestão de segredos, documentação técnica, monitoramento proativo e plano de resposta a incidentes — são tecnicamente viáveis, de custo proporcional ao risco e diretamente alinhados às exigências da LGPD, ISO/IEC 27001/27002 e Resolução ANATEL 740/2020.

Conclui-se que a implementação de um SGSI, mesmo que em escala reduzida e adaptada ao contexto do portal, é não apenas recomendável, mas necessária para que a Vivo mantenha sua posição de conformidade regulatória e proteja adequadamente os dados de seus clientes, funcionários e parceiros comerciais.

"Better safe than sorry."

9. Referências Bibliográficas

BRASIL. **Lei nº 13.709, de 14 de agosto de 2018**. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília, DF: Presidência da República, 2018. Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm

BRASIL. **Lei nº 12.965, de 23 de abril de 2014**. Marco Civil da Internet. Brasília, DF: Presidência da República, 2014. Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2011-2014/2014/lei/l12965.htm

ANATEL. **Resolução nº 740, de 21 de dezembro de 2020**. Regulamento de Segurança Cibernética Aplicada ao Setor de Telecomunicações. Brasília: ANATEL, 2020.

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. **ISO/IEC 27001:2022** — Information security, cybersecurity and privacy protection — Information security management systems — Requirements. Genebra: ISO, 2022.

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. **ISO/IEC 27002:2022** — Information security, cybersecurity and privacy protection — Information security controls. Genebra: ISO, 2022.

PCI SECURITY STANDARDS COUNCIL. **PCI DSS v4.0**. Payment Card Industry Data Security Standard. Wakefield: PCI SSC, 2022. Disponível em: <https://www.pcisecuritystandards.org>

ANPD — Autoridade Nacional de Proteção de Dados. **Guia Orientativo de Segurança da Informação para Agentes de Tratamento de Pequeno Porte**. Brasília: ANPD, 2021.

TELEFÔNICA BRASIL S.A. (VIVO). **Política de Segurança da Informação**. São Paulo: Vivo, 2023. (Documento interno)